



Zero Trust Architecture Implementation

January 29, 2025

Fiscal Year 2024 Report to Congress



**Homeland
Security**

*Cybersecurity and Infrastructure Security
Agency*

Message from the Senior Official Performing the Duties of Director of the Cybersecurity and Infrastructure Security Agency

January 29, 2025

Through our role as America's cyber defense agency, the Cybersecurity and Infrastructure Security Agency (CISA) provides guidance sessions, agency engagement, best practices and additional written guidance to support agency progress on Zero Trust Architecture (ZTA) implementation. Pursuant to the Office of Management and Budget (OMB) Memorandum 22-09, *Moving the U.S. Government Towards Zero Trust Cybersecurity Principles*, CISA has overseen and advised agencies on the development and execution to date of their ZTA implementation plans.



This document has been compiled pursuant to direction in the Senate Report (S.R. 118-85), which accompanies the Fiscal Year (FY) 2024 Department of Homeland Security (DHS) Appropriations Act (Pub.L. No. 118-47). This report provides an update on the status of zero trust implementation across the federal civilian executive branch, including the progress made to date and ongoing challenges with implementation.

This report is provided to the following Members of Congress:

The Honorable Mark Amodei
Chairman, House Appropriations Subcommittee on Homeland Security

The Honorable Lauren Underwood
Ranking Member, House Appropriations Subcommittee on Homeland Security

The Honorable Katie Britt
Chair, Senate Appropriations Subcommittee on Homeland Security

The Honorable Chris Murphy
Ranking Member, Senate Appropriations Subcommittee on Homeland Security

Inquiries relating to this report may be directed to the CISA Office of Legislative Affairs at CISA_OLA@cisa.dhs.gov.

Sincerely,

A handwritten signature in blue ink that reads "Bridget Bean". The signature is fluid and cursive.

Bridget Bean
Senior Official Performing the Duties of Director

Executive Summary

As requested by Congress, this report details progress made by the Federal Civilian Executive Branch (FCEB) agencies in implementing ZTA requirements issued by the Administration in Executive Order (EO) 14028.¹ Overall, agencies have made considerable advancements towards ZTA implementation during the last three years. As required by EO 14028, implementation plans for fiscal years FY 2022–2024 document stakeholder plans to meet the objectives and requirements outlined in The Office of Management and Budget (OMB) Memorandum M-22-09, *Moving the U.S. Government Toward Zero Trust Cybersecurity Principles*.² These plans include strategic and tactical activities supporting the agencies' transitions to ZTA. Through engagements with agencies, CISA gained additional insights on the best practices, lessons learned and range of strategic considerations reflected in this report, which supports three general conclusions:

- **First, agencies are taking a mission-focused approach to ensure ZTA is not implemented in isolation but is instead integrated into an agency's overall strategy, supporting its core functions and long-term objectives.** Agencies' early actions support their unique mission needs and cybersecurity objectives. They have initially adapted existing strategic and tactical activities—such as phishing-resistant multi-factor authentication, endpoint detection and response and network segmentation—to improve overall cybersecurity that support the transition to ZTA. These initial efforts focus on maturing capabilities in the Identity, Device and Network pillars of CISA's Zero Trust Maturity Model (ZTMM) as a foundation of their enterprise transition to ZTA. These early improvements enable longer-term strategic efforts that support the migration to ZTA to be planned and acted upon.
- **Second, agencies are successfully leveraging tools and shared services to drive the formal and rigorous implementation of requirements, including those outlined in M-22-09.** In some cases, agencies document the use of agreed-upon guidance and formal standards; in other cases, agencies leverage CISA programs, such as the High Value Asset (HVA) Program and Continuous Diagnostics and Mitigation Program. CISA's ZTMM serves as a guide for complex implementation decisions, involving programmatic, technical, financial and operational considerations.
- **Third, beyond tactical requirements in M-22-09, implementing ZTA is an ongoing journey with evolving objectives. Progress will require continued investment and leadership focus for years to come.** Evolving technologies, increased reliance on cloud computing, expanding security threats and the need for expertise and a skilled workforce exacerbate enduring challenges. As reflected in many agency implementation plans, ZTA implementation can be complicated by unique mission requirements and needs, some of

¹ Executive Office of the President, "[Executive Order 14028: Improving the Nation's Cybersecurity](#)," May 12, 2021.

² Office of Management and Budget, "[M-22-09 Moving the U.S. Government Toward Zero Trust Cybersecurity Principles](#)," January 26, 2022.

which require compensating security controls and significant changes to network infrastructure.

Agencies have made significant progress in zero trust activities, but work remains to achieve an integrated set of zero trust capabilities that fundamentally reduce enterprise risk. Legacy technical debt and the potential impact of widespread changes to critical mission systems have impeded progress. OMB Memorandum M-24-14, *Administration Cybersecurity Priorities for the FY 2026 Budget*,³ requires agencies to provide updated implementation plans, which will provide additional context to better capture progress, challenges and opportunities for future collaboration moving forward. Increased focus on cross-cutting capabilities and the data pillar can help to ensure a more unified, integrated risk posture. While CISA acknowledges the progress made in many areas of zero trust, we recognize that work remains to achieve the desired state; as a result, CISA remains committed to working with FCEB agencies to reach it.

³ Office of Management and Budget, [“M-24-14 Priorities for the FY 2026 Budget,”](#) July 10, 2024.



Zero Trust Architecture Implementation

Table of Contents

I. Legislative Language	1
II. Background	2
A. Policy and Guidance	2
B. Scope of the Analysis	3
III. Agency Progress	5
Progress Overview	5
General Challenges	5
Progress by Pillar	6
IV. Next Steps.....	19
Ongoing ZTA Implementation Support.....	19
Content and Community	19
V. Conclusion.....	20
Appendix A: Abbreviations.....	21
Appendix B: ZT Community Engagement.....	22

I. Legislative Language

This document was compiled pursuant to the legislative language set forth in the Senate Report 118-85, accompanying the Fiscal Year (FY) 2024 Department of Homeland Security (DHS) Appropriations Act (Pub.L. 118-47), which states:

Zero Trust Architecture Implementation—The committee directs the Department in conjunction with the Office of Management and Budget [OMB] to, within 180 days of the date of enactment of this act, provide a report on the implementation of the last three fiscal years' zero-trust architecture implementation plans agencies must submit to OMB and CISA per the OMB Memorandum M-22-09, Moving the U.S. Government Toward Zero Trust Cybersecurity Principles.

II. Background

This report describes the progress agencies made to implement zero trust and the support and guidance the Cybersecurity and Infrastructure Security Agency (CISA) provided for agency implementation, articulates ongoing challenges associated with zero trust implementation, and outlines next steps for agencies and CISA to take.

A. Policy and Guidance

In May 2021, Executive Order (EO) 14028, *Improving the Nation's Cybersecurity*, established a policy for the Federal Civilian Executive Branch (FCEB) to “take decisive steps to modernize its approach to cybersecurity.”⁴ These steps included adopting security best practices, advancing toward Zero Trust Architecture (ZTA), accelerating movement to secure cloud services, centralizing and streamlining access to cybersecurity data driving analytics for identifying and managing cybersecurity risks, and investing in both technology and personnel to match these modernization goals. To support these efforts, agencies were required to perform the following actions within 60 days:

- Update existing agency plans to prioritize resources for the adoption and use of cloud technology
- Develop a plan to implement ZTA
- Provide a report to the Director of OMB and the Assistant to the President and National Security Advisor discussing the plans⁵

These plans included previously completed actions, identified activities with the most immediate security impact and created an implementation schedule. Some previously completed actions included instituting Multi-factor Authentication (MFA), requiring increased password complexity and encrypting Domain Name System (DNS) traffic. Current activities are discussed later in this report. These tasks all aimed to support response efforts to the increasingly dynamic and sophisticated cyber threat environment.

In January 2022, OMB issued M-22-09, *Moving the U.S. Government Towards Zero Trust Cybersecurity Principles*,⁶ establishing a ZTA strategy aligned to CISA's Zero Trust Maturity Model (ZTMM)⁷ and requiring agencies to meet specific cybersecurity standards and objectives by the end of FY 2024, which emphasized enhanced identity verification, MFA, encryption and continuous monitoring to secure networks, systems and data to minimize risk from both internal and external threats. M-22-09 served as a starting point for agencies transitioning from a conventional, perimeter-based defense to a zero trust approach. Additionally, it highlighted

⁴ Executive Office of the President, “[Executive Order 14028: Improving the Nation's Cybersecurity](#),” May 12, 2021.

⁵ Ibid.

⁶ Office of Management and Budget, “M-22-09 Moving the U.S. Government Toward Zero Trust Cybersecurity Principles,” January 26, 2022, <https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>.

⁷ Cybersecurity and Infrastructure Security Agency (CISA). *Zero Trust Maturity Model*. (April 2023), https://www.cisa.gov/sites/default/files/2023-04/zero_trust_maturity_model_v2_508.pdf.

shared services as necessary to effectively support the path to zero trust, which required careful planning and continuous improvements for agencies to build, deploy and sustain secure capabilities. M-22-09 also instructed agencies to apply the Cloud Security Technical Reference Architecture, which informed agencies of the advantages and risks of adopting cloud-based services into agency modernization efforts.⁸ To further support ZTA implementation across agencies, M-22-09 stated, “OMB and CISA will work with agencies throughout zero trust implementations to capture best practices, lessons learned, and additional agency guidance on a jointly maintained website.”⁹ As a result of successful collaborations with government, industry and academia, CISA developed the ZTMM (updated to v2.0 in 2023); this model presented key facets of information security and communication technology as specific pillars, providing agencies with a clear framework to align and develop their zero trust implementation plans. Figure 1 (below) showcases the five pillars of ZTMM—Identity, Devices, Networks, Applications and Workloads, and Data. The model also included three cross-cutting capabilities—Visibility and Analytics, Automation and Orchestration, and Governance. The ZTMM provided a framework to achieve continuous modernization efforts related to zero trust within a rapidly evolving environment and technology landscape.

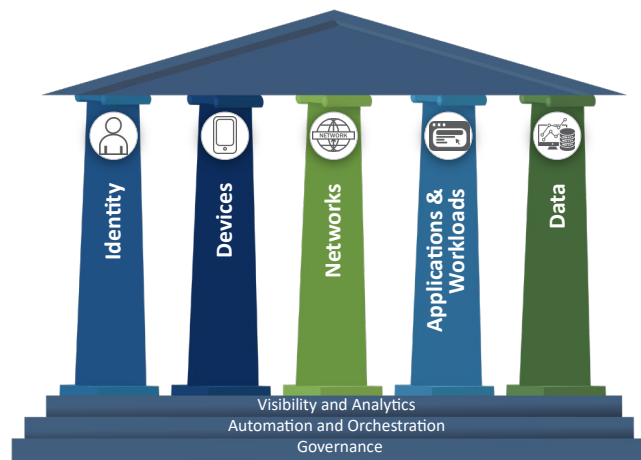


Figure 1: CISA's Zero Trust Maturity Model Pillars

The ZTMM enabled agencies to explore opportunities that improved network resilience, aligned to mission needs and supported other technology pillars. Over time, agencies progressed in the evolution from traditional enterprise protections focused on the perimeter to the future state of zero trust implementation, featuring more dynamic access decisions, automated processes, integrated capabilities and other advanced characteristics of optimal maturity.

B. Scope of the Analysis

⁸ Cybersecurity and Infrastructure Security Agency (CISA), *Cloud Security Technical Reference Architecture*, June 2022, <https://www.cisa.gov/sites/default/files/2023-05/Cloud%20Security%20Technical%20Reference%20Architecture%20v2.pdf>.

⁹ Cybersecurity and Infrastructure Security Agency and The Office of Management and Budget, “Moving the U.S. Government toward Zero Trust Cybersecurity Principles,” Accessed July 25, 2024, <https://zerotrust.cyber.gov/>.

This report provides updates on agencies' zero trust progress, as articulated by agency implementation plans and CISA's ZTMM pillars (shown above in Figure 1). The report included agency challenges to zero trust implementation and ongoing efforts by CISA to address these challenges through content development and active engagement with the FCEB community. Notably, FCEB agencies were only required to provide a single submission of zero trust (ZT) implementation plans in Fiscal Year 2022 (FY 2022), not annually. OMB, Office of the National Cyber Director (ONCD) and CISA reviewed 70 agency plans (24 Chief Financial Officer (CFO) Act agencies and 46 non-CFO) and provided feedback and technical support. As such, the conclusions documented in this report were based on those submissions, data submitted quarterly for Federal Information Security Modernization Act (FISMA) reporting metrics since that time and CISA's anecdotal understanding of progress gleaned from ongoing engagement with agencies from FY 2022 to FY 2024.

The initial implementation plans began zero trust adoption, and available FISMA and CDM metrics provided CISA's primary mechanism for monitoring agency progress. Looking forward, additional metrics are needed to fully understand agency progress and achievement in zero trust implementation.

III. Agency Progress

Progress Overview

Over the last two years, agencies made incremental progress implementing their ZTA plans based on quarterly FISMA reporting, from direct agency engagement and shared lessons learned. Agencies made early progress on activities related to the Identity, Devices and Network Pillars, including bolstering their identity management practices, modernizing user and device authorization processes, integrating cloud-based platforms—such as Secure Access Service Edge (SASE)—enhancing access controls and increasing the restrictions on sharing sensitive information. Investment projects funded by the Technology Modernization Funds (TMF)¹⁰—funding provided through the American Rescue Plan Act (ARPA)—enabled much of the progress to date. Fourteen agencies are executing TMF projects to prioritize and implement specific solutions to meet zero trust policy requirements. Agencies that achieved the most success reported similar contributing factors, including:

- Employing dedicated and knowledgeable staff, often centralized in an agency-level zero trust program management office
- Clearly communicating requirements to leadership and across the enterprise
- Pursuing zero trust capabilities aligned with, or in furtherance of, the agency’s mission and priorities
- Expanding existing technology investments (e.g., upgrading licensing)

General Challenges

Agencies faced budgetary, technical and organizational challenges as they implemented ZTA across their enterprise. These challenges included:

- Operating with constrained budgets required agencies to adjust priorities and strategies to accommodate zero trust implementation and balance it against competing cybersecurity efforts.
- Many legacy technologies required agencies to pursue workarounds, as they could not integrate with zero trust capabilities in the current state.
- Procurement efforts faced similar challenges, as some vendors failed to offer products that meet zero trust requirements (e.g., encrypted protocols support in DNS servers).
- Some zero trust pillars were easier to address than others; as such, agencies made the least progress in areas that require new capabilities rather than off-the-shelf solutions.
- Organizational challenges within some agencies limited their progress toward ZTA, such as a lack of unified, effective and agency-wide governance processes or skillsets.
- The visibility and analytics, automation and orchestration and governance cross-cutting capabilities were designed by CISA to benefit the overall ZTA migration process and deserved greater visibility.

¹⁰ Technology Modernization Fund, “[Our Investments](https://tmf.cio.gov/projects),” October 7, 2024, <https://tmf.cio.gov/projects>.

Progress by Pillar

Agency progress was measured by pillar, with each pillar given a section. Each section noted both the vision statement and security goals at the beginning of the section, as outlined in M-22-09. These goals were organized around the specific actions that were considered the “highest value starting points on the path to a zero-trust architecture.” Then, it summarized implementation progress and challenges within that pillar, leveraging structured data where available. CISA leveraged the following data sources: FISMA Chief Information Officer (CIO) metrics from FY 2022-2024, implementation and results reporting captured by the Continuous Diagnostics and Mitigation (CDM) Program and data associated with ZT TMF projects. Where there was no supporting metric data, CISA included insights into progress derived through ongoing collaboration through CISA’s Zero Trust Community engagements (see Appendix B) beginning in FY 2022 and continuing through the present; while anecdotal in nature, these insights illustrated progress trends.



IDENTITY

Vision: Agency staff use enterprise-managed identities to access the applications they use in their work. Phishing-resistant multi-factor authentication (MFA) protects those personnel from sophisticated online attacks.¹¹

Actions

1. Agencies must employ centralized identity management systems for agency users that can be integrated into applications and common platforms.
2. Agencies must use strong MFA throughout their enterprise.
 - MFA must be enforced at the application layer, instead of the network layer.
 - For agency staff, contractors and partners, phishing-resistant MFA is required.¹²
 - For public users, phishing-resistant MFA must be an option.
 - Password policies must not require use of special characters or regular rotation.
3. When authorizing users to access resources, agencies must consider at least one device level signal alongside identity information about the authenticated user.¹³

Analysis of Agencies’ Implementation Plan Progress

¹¹ Office of Management and Budget, “M-22-09 Moving the U.S. Government Toward Zero Trust Cybersecurity Principles,” January 26, 2022. <https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>

¹² Cybersecurity and Infrastructure Security Agency. “Implementing Phishing-Resistant MFA.” Implementing Phishing-Resistant MFA, October 2022. <https://www.cisa.gov/sites/default/files/2023-01/fact-sheet-implementing-phishing-resistant-mfa-508c.pdf>.

¹³ Ibid.

As seen in Figure 2 (below), phishing-resistant MFA implementation increased significantly across the FCEB agencies, following the M-22-09 mandate, as tracked through FISMA metrics. This showed demonstrable progress from M-22-09 issuance and continued through the last reporting cycle. Additionally, as shown in Figure 2, even agencies that have been unable to fully implement phishing-resistant MFA found some success by using an incremental MFA solution to mitigate identity-oriented risk. Through these actions, agencies demonstrated a greater understanding that interim risk mitigations are more important to mission assurance than waiting for a more comprehensive solution with an indeterminate implementation schedule.

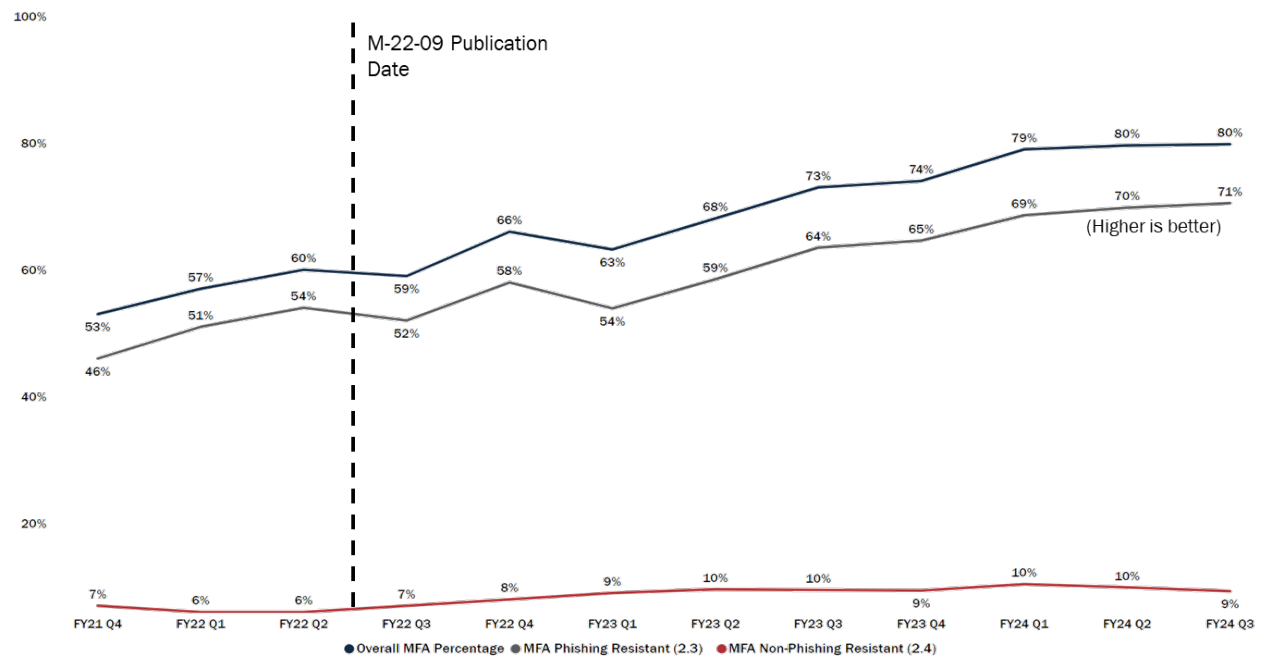


Figure 2: MFA and Phishing-Resistant MFA Implementation

In July 2023, CISA gathered best practices and insights from agencies that achieved greater than 90 percent implementation targets for MFA and encryption, in order to understand their commonalities to share with the broader FCEB. Success factors common to these agencies included the following:

- Strong leadership support;
- Extensive collaboration during planning and implementation phases with broadly representative agency stakeholders;
- Using risk information to target financial resources more effectively;
- Utilization of existing frameworks, such as General Services Administration’s Federal Risk and Authorization Management Program (FedRAMP), to support risk-informed resourcing decisions; and
- Embracing the concepts of centralized governance and continuous, incremental improvement.

Successful agencies prioritized phishing-resistant MFA and encryption for all new systems, at times refusing to grant Authority to Operate in the absence of such measures. These agencies

also enforced compliance through the stringent adherence to updated policy and procedures, shifting their organizational culture towards a security-centric ethos. Finally, they continued enterprise-wide efforts to centralize environments, data and policy enforcement, in order to adjust identity systems and access controls, as needed. Agencies that found early success relied heavily on the adoption of a centralized approach to manage Identity, Credential, and Access Management (ICAM) and the ability to make incremental changes to existing enterprise services, including phishing-resistant MFA.

Identity Challenges

CISA's communication with the FCEB agencies identified specific challenges when implementing Identity-focused M-22-09 requirements. These included:

- ICAM services were not consistently defined or available from shared service providers, which impeded a holistic access management and services approach.
- There was a lack of open standards and technical profiles for secure, interoperable identity lifecycle and access management services (e.g., Open Authorization 2.0, OpenID Connect, Security Assertion Markup Language 2.0, System for Cross-domain Identity Management 2.0).
- There were substantial interoperability challenges when shifting from legacy, on-premises architectures to hybrid and cloud-native services.
- The lack of ICAM standards for federal business lifecycle services—such as human capital management, official travel and financial management—failed to translate into federal ICAM business standards or shared services.
- Small agencies lacked shared service options (e.g., Identity as a Service/ Identity and Access Management, Privileged Access Management, Identity Lifecycle Management, Identity Governance and Administration, etc.), which was exacerbated by a shortage of ICAM technical expertise.
- There were no trust agreements to establish trusted identity reciprocity technical guidance and shared services for access federation for FCEB interagency and mission partners.

The tremendous complexity and diversity of highly federated departments presented challenges, due to siloed information technology (IT) environments across their enterprises. Historically speaking, larger agencies necessarily divided into many diverse bureaus with varying levels autonomy as necessitated for their specific mission requirements. This complexity and compartmentalization directly impacted the ability to implement a centralized identity management system across the whole of the agency, which further limited the viability of broad MFA adoption and useful device-level signaling. Additionally, the volume of mainframe and other legacy systems presented a notable challenge for most agencies, especially in implementing security measures retroactively. This created a particular problem for legacy systems, which simply lacked the capability to address modern identification and authorization security requirements as described by M-22-09's identity actions. Finally, ICAM services were not consistently defined or available from any shared services providers. This diversity of design, capabilities and functions across providers complicated any attempt to merge existing

divergent identity management systems into a single holistic solution, creating substantial interoperability and integration obstacles.

The absence of commonly defined shared services, diversity of standards and implementations, and the lack of a unified identity management system all presented challenges to MFA implementation. While hybrid and cloud native solutions may have been able to incorporate some shared service options, they may not be optimal for all circumstances, particularly small agencies with limited resources and ICAM technical expertise. A unified vision for identity management would support the migration of federated departments to a single identity management solution and aid in identity reciprocity across agencies. Finally, because MFA capability must be incorporated into each unique identity management system, more identity management systems deployed in an agency require greater initial integration requirements and ongoing maintenance efforts.

The identity outcomes prioritized in M-22-09 and 2023-2024 FISMA CIO Metrics straightforwardly defined expected policy enforcement results for federal information systems. Since M-22-09 was published, the federal interagency has learned a great deal from the Fast Identity Online v2 (FIDO2) Community of Action (chartered under the CIO Council) and identity services pilot programs led by CISA and other agencies. Although these efforts generated guidance, tools and experience shared broadly across federal agencies, the limited usage of centralized governance processes across the FCEB inhibited progress in implementing a unified identity management approach.

In summation, agencies accomplished a substantial increase in MFA implementation and continue to work on unified identity management. CISA will continue to enable these efforts.



DEVICES

Vision: Agencies maintain a complete inventory of every device authorized and operated for official business and can prevent, detect and respond to incidents on those devices.¹⁴

Actions

1. Agencies must create reliable asset inventories through participation in CISA's CDM program.
 - CISA will design the CDM program to better support a cloud-oriented Federal architecture.
2. Agencies must ensure their Endpoint Detection and Response (EDR) tools meet CISA's technical requirements and are deployed widely.

¹⁴ Office of Management and Budget, "[M-22-09 Moving the U.S. Government Toward Zero Trust Cybersecurity Principles](#)," January 26, 2022.

- Agencies must work with CISA to identify implementation gaps, coordinate the deployment of EDR tools, and establish information-sharing capabilities, as described in M-22-01.¹⁵

Analysis of Agencies' Implementation Plan Progress

A growing number of agencies employed CISA's CDM capabilities. Many also developed and deployed asset management inventories. This demonstrated an increasing ability to build asset inventories, to view systems comprehensively and to assess their value and security posture. Integrating that data with CDM allowed agencies to leverage CISA's CDM Dashboard to generate effective asset inventories and collaborate with CISA to identify their HVAs and design effective risk mitigation measures. The CDM Program supported agency efforts by providing dashboards containing asset inventory data. Agencies validated the inventories collected by CDM in the FISMA reporting tool maintained by CISA. Agencies possessed the ability to modify the inventory, filling in gaps in CDM coverage for specific types of assets (e.g., Internet of Things or). CISA worked diligently with the enterprise to improve asset management capabilities. Efforts included working with agencies to develop initial asset baselines and developing plans to target coverage gaps. The results of that partnership culminated in FCEB agencies making notable progress in increased Asset Management Baseline coverage. Overall progress showed a distinct improvement—33 percent to 55 percent of agencies achieving over 90 percent of Hardware Asset Coverage and 18 percent to 39 percent of agencies reaching over 90 percent of Software Coverage. Since the introduction of eight CDM automated FISMA metrics, device type categorization in CDM showed significant progress. Notably, there was a decrease of "Unknown/Uncategorized" Device Types from 55 percent in FY 2023, Q1 to just under 5 percent in FY 2024, Q3.

¹⁵ Ibid.

CDM Progress Summaries – EDR

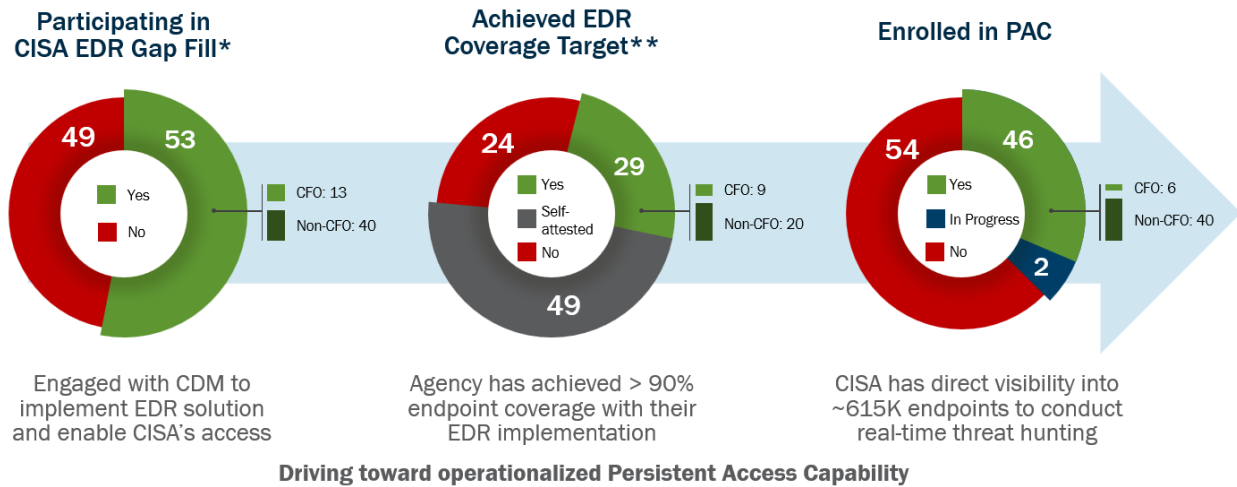


Figure 3 EDR Deployment

In addition to the basic asset and EDR implementation information required by M-22-09, agency CDM dashboards supported incident response, enabled proactive vulnerability management and ingested CISA's known exploited vulnerabilities list to enrich vulnerability data. These dashboards provided agencies and CISA analysts with information of greater contextual value to increase situational awareness and insight. This allowed stakeholders to better understand exposure to active and exploited vulnerabilities. Also, the richness of information available in the dashboards has enabled additional risk-informed business responses, increased risk reduction and resulted in continuous improvements to the quality of the data available to risk managers.

OMB M-22-01, *Improving Detection of Cybersecurity Vulnerabilities and Incidents on Federal Government Systems through Endpoint Detection and Response*, dictates the adoption of EDR solutions and works to improve visibility into and detection of cybersecurity vulnerabilities and threats to the government, as defined in EO 14028.¹⁶ Additionally, as illustrated in Figure 3, agencies used CISA-facilitated EDR capabilities that provided data on hardware and software assets. These metrics indicated that agencies showed progress toward their advanced zero trust capabilities through configuration and vulnerability management. This additional data supported advanced dynamic policy-based access decisions and provided CISA with increased visibility into and detection of cybersecurity vulnerabilities and threats across FCEB agencies that have onboarded with CISA's Persistent Access Capability (PAC). The following items illustrated specific milestones in the adoption of EDR capabilities:

- The EO helped prioritize and ARPA helped fund agency progress on this task, in part, through engagement with CISA's CDM Program which offers EDR capabilities.

¹⁶ Office of Management and Budget, "M-22-01: [Improving Detection of Cybersecurity Vulnerabilities and Incidents on Federal Government Systems through Endpoint Detection and Response](https://www.whitehouse.gov/wp-content/uploads/2021/10/M-22-01.pdf)," October 8, 2021, <https://www.whitehouse.gov/wp-content/uploads/2021/10/M-22-01.pdf>.

- As of FY 2024, 99 FCEB agencies (23 CFO Act agencies and 76 non-CFO) are employing EDR capabilities which meet CISA requirements.
- As of July 2024, 53 FCEB agencies worked with CISA to deploy a full EDR implementation tool.
- As of Q4 FY 2024, CISA has enrolled 46 FCEB agencies in their CDM-deployed EDR capabilities which provide CISA visibility and detection of cybersecurity vulnerabilities and threats through PAC functionality.

Device Challenges

Agencies lacked the resources and procurement options to integrate new and legacy IT components. Legacy IT presented a particular issue, as those systems can be susceptible to known vulnerabilities and may not be compatible with advanced capabilities and newer security standards. The tremendous complexity of IT environments, particularly in highly federated departments and those with non-traditional assets, made enterprise-level inventory and visibility a challenge. Also, while network segmentation was intended to mitigate risks related to these non-traditional asset types, it further complicates these issues. Agencies lacked the capabilities to enable zero trust principles on operational technologies, such as Industrial Control Systems, as these systems were not always compatible with or capable of contemporary security practices.

In summation, agencies accomplished extensive EDR deployment and continue to work on including OT and other non-traditional assets in their hardware inventories. CISA will continue to enable these efforts.



NETWORKS

Vision: Agencies encrypt all DNS requests and Hypertext Transfer Protocol Secure (HTTPS) traffic within their environment and begin executing a plan to break down their perimeters into isolated environments.¹⁷

Actions

1. Agencies must resolve DNS queries using encrypted DNS wherever it is technically supported.
 - CISA's Protective DNS program will support encrypted DNS requests.
2. Agencies must enforce HTTPS for all web and application program interface traffic in their environment.
 - Agencies must work with CISA to "preload" their .gov domains into web browsers as only accessible over HTTPS.

¹⁷ Office of Management and Budget, "[M-22-09 Moving the U.S. Government Toward Zero Trust Cybersecurity Principles](https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf)," January 26, 2022. <https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>

3. CISA will work with FedRAMP to evaluate viable Government-wide solutions for encrypted email in transit and to make resulting recommendations to OMB.
4. Agencies must develop a zero-trust architecture plan that describes the agency's approach to environmental isolation in consultation with CISA and submit it to OMB as part of their zero-trust implementation plan.¹⁸

Analysis of Agencies' Implementation Plan Progress

Agencies initiated several zero trust-related pilot efforts, including integration of SASE and cloud platforms with CISA's Protective DNS and deployment of encrypted DNS protocols. Since CISA's Protective DNS went live in September 2022, 92 percent of federal agencies onboarded with CISA's Protective DNS service, representing over 99 percent of federal external DNS traffic. This achievement included successful collaboration with major vendors to make their network and DNS technology platforms compatible with CISA's offerings, adding encrypted DNS protocols and other features to commercial product roadmaps.

In May 2023, CISA and OMB stood up a DNS Modernization Community of Action with eight agencies. This community set to work on four objectives to help address technology gaps in DNS infrastructure by working with vendors, testing and deploying technologies under development to support DNS encryption. As a direct result of these efforts, four SASE vendors integrated with CISA's protective DNS and allowed agency customers to route DNS traffic from previously unsupported devices and environments to Protective DNS. Finally, in April 2024, CISA published the *Encrypted DNS Implementation Guidance* to assist agencies with encrypted DNS protocol deployment, where technically feasible.

- In response to the critical requirement for federal agencies to enhance the security of their online presence, as mandated in the Consolidated Appropriations Act, 2021, CISA collaborated closely with federal agencies to preload agency-owned .gov domains as HTTPS-only in web browsers.¹⁹ This initiative secured a crucial step in safeguarding the integrity and confidentiality of government communications and services delivered through the web.

CISA's Vulnerability Management Cyber Hygiene reports confirmed that agencies have been consistently above 90 percent compliance of Binding Operational Directive (BOD) 18-01 requirements since January 2022, and weekly reports provided to the entire FCEB showed all reporting elements to include: Hypertext Transfer Protocol Secure/HTTP Strict Transport Security (HTTPS/HSTS) uptake and whether websites/services support HTTPS, enforce HTTPS, utilize strong HSTS and disable weak cryptosecurity.

Networks Challenges

¹⁸ Ibid.

¹⁹ Consolidated Appropriations Act, 2021 (Pub. L. No: 116-260), <https://www.congress.gov/bill/116th-congress/house-bill/133>.

The lack of vendor support, legacy technologies issues and funding difficulties continued to present major challenges in aligning agency networks with zero trust principles. Many existing technologies, including legacy platforms, still lacked encrypted DNS protocols. At the time M-22-09 was released, the most prevalent technologies deployed throughout the federal enterprise were not capable of communicating over encrypted DNS protocols. This included lack of support for encrypted DNS protocols in DNS server infrastructure, endpoint operating system native stacks (including mobile devices) and cloud infrastructure. As a direct result of CISA's engagements with infrastructure vendors, many vendors fully integrated with CISA's Protective DNS and were slowly adding encrypted DNS protocols to their technology roadmaps. These included the aforementioned DNS service and SASE vendors and cloud service providers. Given the lengthy time to integrate additional capabilities, it may take some time before technologies on agency networks are fully capable of encrypting DNS traffic across the enterprise.

Agencies experienced difficulties in determining the most effective way to develop a migration plan for environmental isolation. While agencies have a basic understanding of the concepts of Zero Trust Network Access, Next Generation Firewalls, Secure Service Edge and SASE, determining where to best begin their migration efforts remains a considerable challenge. Some of the specific challenges included:

- Determining the best solution for their current level of zero trust maturity
- Developing integration plans for the wide range of legacy and contemporary resources
- Determining prerequisite requirements for potential solutions
- Developing an architectural roadmap to evolve from their current state to an optimal maturity level

Vendor compatibility, varying degrees of actionable and factual solution details and the sheer complexity of addressing the requirement in an operational environment added to the complexity of developing a viable plan. In response to this need, CISA documented the capabilities of each solution, the prerequisites and considerations for each and decision support guidance to help agencies select the best solution for their specific operational needs.

In summation, agencies made substantial progress in securing DNS communication and continue to work on issues related to vendor compatibility and solution integration challenges. CISA will continue to enable these efforts.



APPLICATIONS & WORKLOADS

Vision: Agencies treat all applications as internet-connected, routinely subject their applications to rigorous empirical testing, and welcome external vulnerability reports.²⁰

Actions

²⁰ Office of Management and Budget, "M-22-09 Moving the U.S. Government Toward Zero Trust Cybersecurity Principles," January 26, 2022. <https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>

1. Agencies must operate dedicated application security testing programs.
2. Agencies must utilize high-quality firms specializing in application security for independent third-party evaluation.
 - CISA and General Services Administration (GSA) will work together to make the services of such firms available for rapid procurement.
3. Agencies must maintain an effective and welcoming public vulnerability disclosure program for their internet-accessible systems.
4. Agencies must identify at least one internal-facing FISMA Moderate application and make it fully operational and accessible over the public internet.
5. CISA and GSA will work together to provide agencies with data about their online applications and other assets.
 - Agencies must provide any non-.gov hostnames they use to CISA and GSA.
6. Agencies should work toward employing immutable workloads when deploying services, especially in cloud-based infrastructure.²¹

Analysis of Agencies' Implementation Plan Progress

In this pillar, CISA found that agencies were in lower levels of zero trust maturity than in the Identity, Device and Networking pillars. This was likely due to a greater level of existing technical expertise and external support in the other pillar areas combined with the requirement to greatly re-engineer existing development processes to incorporate Development, Security, and Operations (DevSecOps) principles. Agencies implemented targeted measures by utilizing automated tools and manual processes for testing and analysis, where operationally viable, while also leveraging services provided by CISA, which contributed to agency progress.

As of beginning of Q4 FY 2024, 51 agencies have onboarded with CISA's Vulnerability Disclosure Program (VDP) platform. This service helped participating agencies streamline day-to-day operations when disclosing and managing cyber vulnerabilities. The VDP platform served as the primary point for receiving, triaging, and routing vulnerabilities disclosed by public researchers. The platform also automatically reported required metrics to CISA through CyberScope, saving agencies significant time and resources. Additionally, 47 agencies established their own internal programs in line with the requirements of BOD 20-01, *Develop and Publish a Vulnerability Disclosure Policy*.²² Agencies developed and published vulnerability disclosure policies and several maintain a mailbox for receiving vulnerability reports about internet-facing systems. Additionally, CISA's Federal Attack Surface Testing Team incorporated 26 agencies into their continuous penetration testing of internet-facing assets. The advanced penetration testing team identifies and recommends fixes for unique vulnerabilities that cannot be found with traditional scanning tools.

Applications & Workload Challenges

²¹ Ibid.

²² Cybersecurity and Infrastructure Security Agency, "BOD 22-02: Reducing the Significant Risk of Known Exploited Vulnerabilities: CISA," June 13, 2023, <https://www.cisa.gov/news-events/directives/bod-22-01-reducing-significant-risk-known-exploited-vulnerabilities>.

The prevalence of vulnerabilities within commercially available applications and Software as a Service solutions contributed to an environment where significant resources must be expended to detect vulnerabilities and either remediate or mitigate the associated risks. While agencies have completed initial steps in addressing vulnerability detection, they remain challenged by resource constraints, such as technical capabilities and the required staffing to carry out more comprehensive automated and manual application security testing.

Additionally, the implementation of immutable workloads represented a significant departure from existing software development practices and required supplemental resources to re-engineer the process. This challenge was further compounded by the sheer volume of application source code, particularly legacy code, required to migrate more contemporary practices, such as “Secure by Design” and the use of the DevSecOps framework. Finally, the fact this transition must occur without a negative impact on agency operations necessitates meticulous care and planning when implementing these capabilities.

In summation, agencies accomplished initial implementation of vulnerability detection and reporting mechanisms and continue to work on enhancing vulnerability detection capabilities and the implementation of contemporary application coding practices and immutable workloads. CISA will continue to enable these efforts.



DATA

Vision: Agencies are on a clear, shared path to deploy protections that make use of thorough data categorization. Agencies take advantage of cloud security services and tools to discover, classify, and protect their sensitive data and have implemented enterprise-wide logging and information sharing.²³

Actions

1. Federal Chief Data Officers and Chief Information Security Officers (CISO) will create a joint committee to develop a zero-trust data security guide for agencies.
2. Agencies must implement initial automation of data categorization and security responses, focusing on tagging and managing access to sensitive documents.
3. Agencies must audit access to any data encrypted at rest in commercial cloud infrastructure.

Agencies must work with CISA to implement comprehensive logging and information sharing capabilities, as described in OMB Memorandum M-21-31, *Improving the Federal*

²³ Office of Management and Budget, “M-22-09 Moving the U.S. Government Toward Zero Trust Cybersecurity Principles,” January 26, 2022, <https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>

Analysis of Agencies' Implementation Plan Progress

Agencies continued to make progress in overall data security by using Data at Rest (DAR) and Data in Transit (DIT) encryption. Figure 4 (below) reflected agencies' progress in implementation of both modes of encryption, thus demonstrating a continuous commitment to strengthening data-related security controls from the beginning of FY 2023 to present.

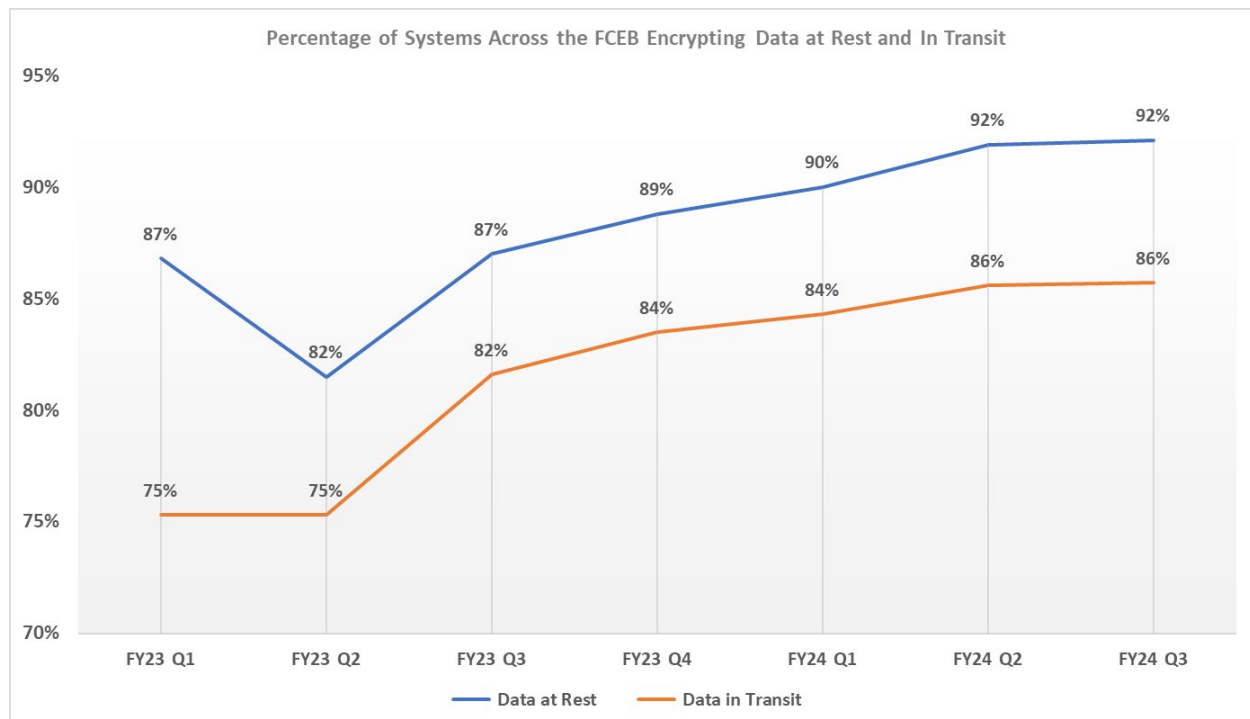


Figure 4: Systems Across FCEB Encrypting Data

As a collaborative effort of federal agencies, OMB and CISA, the Zero Trust Data Security Working Group identified a set of actions and plans to move forward on Data pillar progress. This plan will guide agency efforts to improve capabilities in the Data pillar.

The recently released *Federal Zero Trust Data Security Guide* provides foundational knowledge, which will be key to agencies' data strategy refinement.²⁶ This guide enables much more granular controls for policy enforcement points, promoting identification and application of

²⁴ Office of Management and Budget, "M-21-31: Improving the Federal Government's Investigative and Remediation Capabilities Related to Cybersecurity Incidents," August 27, 2021, <https://www.whitehouse.gov/wp-content/uploads/2021/08/M-21-31-Improving-the-Federal-Governments-Investigative-and-Remediation-Capabilities-Related-to-Cybersecurity-Incidents.pdf>.

²⁵ Office of Management and Budget, "M-22-09 Moving the U.S. Government Toward Zero Trust Cybersecurity Principles," January 26, 2022, <https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>.

²⁶ Chief Information Officer Council, *Federal Zero Trust Data Security Guide*, October 2024, https://www.cio.gov/assets/files/Zero-Trust-Data-Security-Guide_Oct24-Final.pdf.

appropriate protections based on data attributes, thus improving risk reduction and cost effectiveness. Coupled with integration of the progress made in the other pillars, this understanding is central to fully realizing the benefits of FCEB's efforts to date.

Data Challenges

The Data pillar presented several challenges. Agencies would benefit from the development of additional guidance on topics such as common taxonomies, classification markings, controlled access, file format complexity, static classification, access control decisions and data tagging. While the needs associated with other pillars received attention from commercial service providers, fewer resources were available to address the capabilities of the Data pillar. The overall risk reduction goals of ZTA could not be achieved without an increased focus on developing and executing an effective data strategy. However, it was critical to understand that those efforts will take some time to bear fruit, due to the scope and complexity of the issues and lack of maturity in overall data governance.

Across the board, agencies reported that meeting the ZTA data requirement was particularly challenging, as there is a wide range of structured and unstructured data types and current data characterization approaches do not support effective access controls. Additionally, agencies communicated that the sheer volume of both legacy and newly generated data presents further complications in evolving data categorization and cataloging-related capabilities. Finally, agencies disclosed that the categorization challenge was compounded by the fact that monitoring data objects requires data inventory details that exceed the capabilities of current processes and procedures.

In summary, agencies accomplished a great deal in implementing DAR and DIT encryption and continue to work on the substantial challenges related to data categorization and cataloging. CISA will continue to support these efforts.

IV. Next Steps

Ongoing ZTA Implementation Support

CISA will continue to work to help FCEB agencies progress toward fully realizing ZTA. To address the challenges facing the enterprise, CISA will continue to partner with ONCD and OMB to understand and evaluate agency progress against agency implementation plans and prioritize and align technical needs, resources, guidance and capabilities moving forward. While individual agency implementation plans will differ, the high-level tasks and milestones required to implement zero trust principles are similar across the enterprise.

Content and Community

To address common challenges impeding ZT progress, CISA will issue targeted zero trust guidance focusing on challenges that hinder agencies' zero trust efforts. This risk-based guidance will help connect the concepts in the ZTMM and specific technical challenges, as well as leverage CISA products and shared services, including CDM. Additionally, CISA will provide subject matter expertise and thought leadership to assist agencies in ZT implementation by sharing ZT best practices and lessons learned through CISA's ZT Community. CISA will partner with agencies to advocate innovative approaches, automation and risk-based prioritization of ZT guidance and activities to help ensure existing governance processes improve. Like much of cybersecurity, ZT concepts must be understood and adopted across the enterprise in order to be successful.

V. Conclusion

This report fulfilled CISA's requirement in the Senate Report accompanying the Department of Homeland Security Appropriations Act, 2024 to report on agencies' progress in implementing zero trust plans for the period of FY 2022 – FY 2024. This report described the actions CISA is taking, in conjunction with OMB, to help agencies complete required actions by the end of FY 2024.

Zero trust has become a priority for agencies, both internally to their respective agencies and externally working with CISA and OMB. Agencies developed high-level strategies and identified the specific zero trust pillars that require the highest level of emphasis and resources to improve agency-wide security. CISA intends to further drive and support adoption of modern security practices, to include zero trust principles and secure cloud implementations. CISA will partner with OMB and ONCD to help ensure agencies' long-term plans align with and enable enterprise-wide operational needs, such as defensible networks, operational visibility and expedited incident response.

Appendix A: Abbreviations

Abbreviation	Description
ARPA	American Rescue Plan Act
BOD	Binding Operational Directive
CDM	Continuous Diagnostics and Monitoring
CFO	Chief Financial Officer
CIO	Chief Information Officer
CISO	Chief Information Security Officer
CISA	Cybersecurity and Infrastructure Security Agency
COA	Community of Action
DAR	Data at Rest
DevSecOps	Development, Security, and Operations
DIT	Data in Transit
DNS	Domain Name System
EDR	Endpoint Detection & Response
EO	Executive Order
FCEB	Federal Civilian Executive Branch
FISMA	Federal Information Security Modernization Act
FedRAMP	Federal Risk and Authorization Management Program
FIDO2	Fast Identity Online v.2
FY	Fiscal Year
GSA	General Services Administration
HSTS	HTTP Strict Transport Security
HTTP	Hypertext Transfer Protocol
HTTPS	Hypertext Transfer Protocol Secure
HVA	High Value Asset
ICAM	Identity, Credential, and Access Management
MFA	Multi-Factor Authentication
NIST	National Institute of Standards and Technology
OMB	Office of Management and Budget
ONCD	Office of the National Cyber Director
PAC	Persistent Access Capability
SASE	Secure Access Service Edge
TMF	Technology Modernization Fund
VDP	Vulnerability Disclosure Platform
ZT	Zero Trust
ZTA	Zero Trust Architecture
ZTMM	Zero Trust Maturity Model

Appendix B: ZT Community Engagement

List of the Interagency Zero Trust Community Engagements

- **Collaborative Efforts:** The Zero Trust Architecture Community of Interest (ZTA-COI) at National Institute of Standards and Technology (NIST) and the Zero Trust Inter-Agency Steering Group convened by the CIO Council work together to advance zero trust initiatives across federal agencies.
- **CyberStat Workshops:** Following the publication of EO 14028 and OMB M-22-09, CISA hosted thirty-seven ZT-related workshop sessions for federal agencies. These workshops drew several thousand Federal IT professional attendees from across the government.
- **Data Security Working Group:** Established by the Treasury Department and OMB in May 2023, this group helps agencies meet the data requirements of OMB M-22-09. The working group is developing the “Zero Trust Data Security Guide” with completion expected by the end of FY 2024. The group meets monthly to refine data criteria and enhance federal data security frameworks.
- **DNS Modernization Community of Action (COA):** In May 2023, CISA and OMB stood up a Domain Name System (DNS) Modernization CoA. A cohort of eight agencies set to work on four objectives to address technology gaps in DNS infrastructure by working with member agencies to configure and deploy technologies that can support DNS encryption, develop implementation guidance, and engage vendors to add new encrypted DNS protocols to their product roadmaps.
- **ICAM Subcommittee and Community of Practice (COP):** Supported by the Federal CISO Council and GSA, the subcommittee oversees federal ICAM initiatives and promotes FIDO2 standards for phishing-resistant authentication. GSA and the Department of Health and Human Services Center for Disease Control and Prevention also lead the ICAM COP, advancing ICAM technologies and improving federal identity management.
- **Federal Zero Trust Managers Community of Practice:** Supported by CISA’s Zero Trust Initiative, this group facilitates the exchange of zero trust best practices. The group meets virtually monthly and in person on a quarterly basis to discuss strategies, with contributions like the Security Orchestration, Automation, and Response Playbook and a zero trust overlay for NIST 800-53 from the Department of Education.
- **Federal Zero Trust Network Modernization Working Group:** This is a forum for federal network professionals to drive progress in modernizing the federal enterprise networks with the Federal Zero Trust Strategy and CISA services. The group focuses on articulating the changes in the federal IT landscape and associated protections. It also focuses on restoring visibility that CISA and agencies are losing due to migrations away from traditional on-premises networks. To compensate for this migration, the working group is designing and implementing next generation protections for the federal enterprise that are required to cope with the ongoing changes to the IT landscape.
- **Greenfield Zero Trust Native Environment Working Group:** Led by the Department of the Interior, this group focuses on implementing zero trust in new environments, free from legacy system constraints.